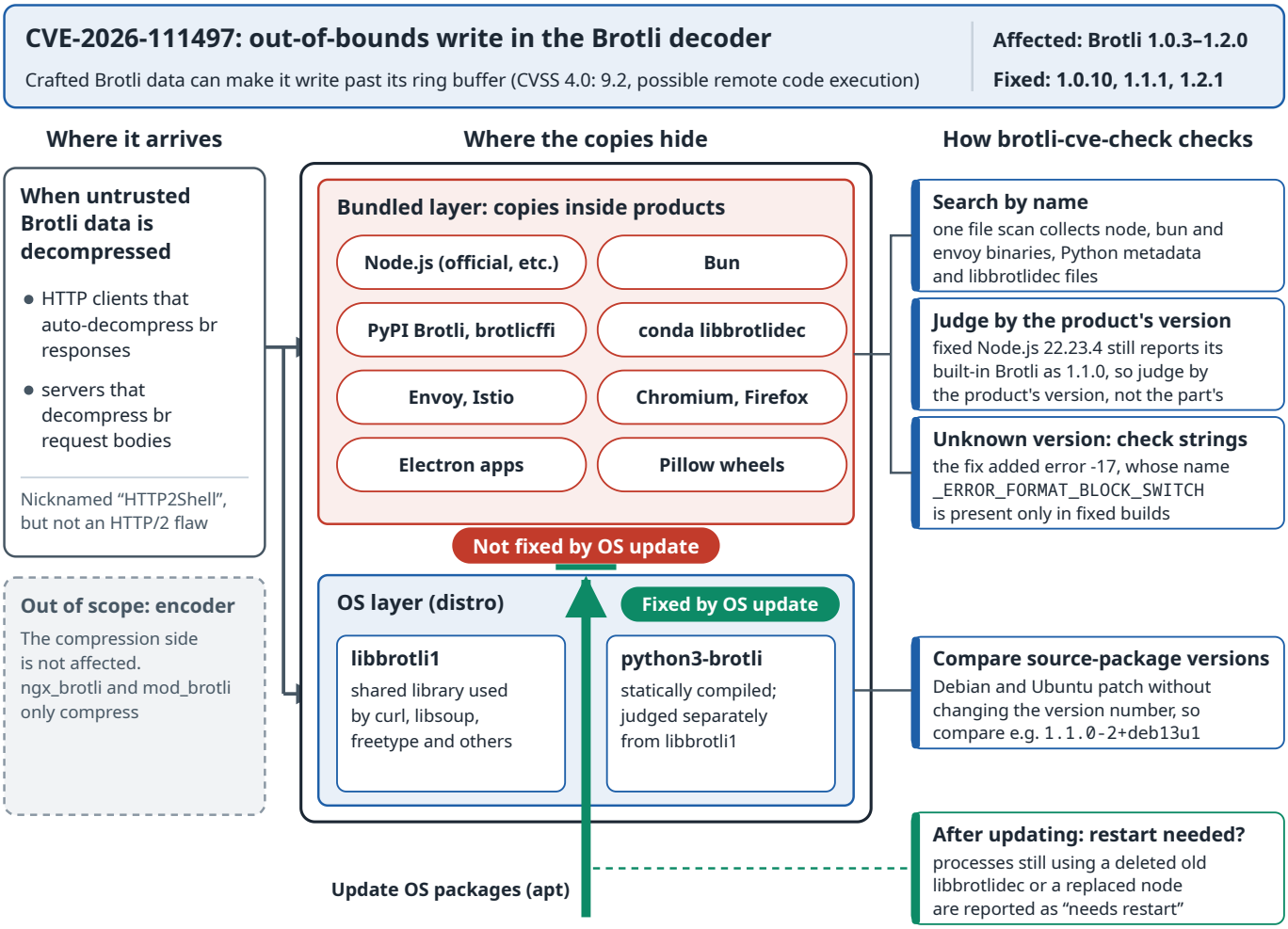
Fig. 01 What we checked, and how CVE-2026-111497



How to read this page

1. **The flaw is on the decompression side (the decoder) and is reached whenever untrusted Brotli data is decompressed.** Paths include clients that auto-decompress HTTP `Content-Encoding: br` responses and servers that decompress br request bodies. Upstream fixed it in 1.0.10, 1.1.1 and 1.2.1 on 2026-10-21 (GHSA-9v8h-qqgm-4m35).
2. **Bundled copies need each product's own update** (**updating the OS does not fix them**). Fixed versions include Node.js 22.23.4 / 24.22.1 / 26.12.1, Bun 1.4.4 and PyPI Brotli 1.2.1. The string check was verified on self-built Brotli 1.2.0 / 1.2.1, official Node.js binaries and PyPI wheels; builds whose error-name table was stripped are not judged but reported as `VENDORED_COPY` (needs review). As of 2026-10-26, Ubuntu has no fixed OS packages yet (Debian 12 and 13 do).
3. **Read-only, and it never says "safe".** It writes only to standard output and `--output`, and uses neither the network nor attack data. Programs it finds are run only to ask `--version`, with an empty environment, a time limit, and only from places no one else can replace. If urllib3, requests, httpx or aiohttp sit next to Brotli, it shows them as a hint that responses are auto-decompressed (not a vulnerability in itself). It always lists what it did not scan, and it does not check for intrusion.

Updating the OS fixes only the OS's copy, so bundled copies must be found and told apart one by one, by version and by strings.

Next step Verify the SHA256, run `sudo bash brotli-cve-check` (read-only), then update or restart whatever it lists under "Needs update" and "Needs restart" first.

Sources: GHSA-9v8h-qqgm-4m35, PYSEC-2026-4322, brotli-cve-check v0.1.0 docs